CAPSTONE PROJECT: NETWORK VULNERABILITY ASSESSMENT REPORT

Target Environment: Metasploitable2 (`192.168.56.103`)
Attacker Environment: Kali Linux Host-Only Network (`192.168.56.x`)

---

1. Executive Summary & Methodology

This report documents the practical execution steps, commands run, evidence collected, and mitigation strategies formulated during the assessment of the Metasploitable2 target virtual machine at IP `192.168.56.103`.

The testing process followed an industry-standard methodology:

1. **Host Discovery:** Confirming target reachability.
2. **Port & Service Enumeration:** Mapping open ports, services, and running versions.
3. **Aggressive OS & Script Scanning:** Identifying fingerprint information and automated script matches.
4. **Vulnerability Detection:** Running targeted Nmap Scripting Engine (NSE) modules.
5. **Traffic Capture Analysis:** Auditing plain-text transmission over local host-only interfaces using Wireshark.

---

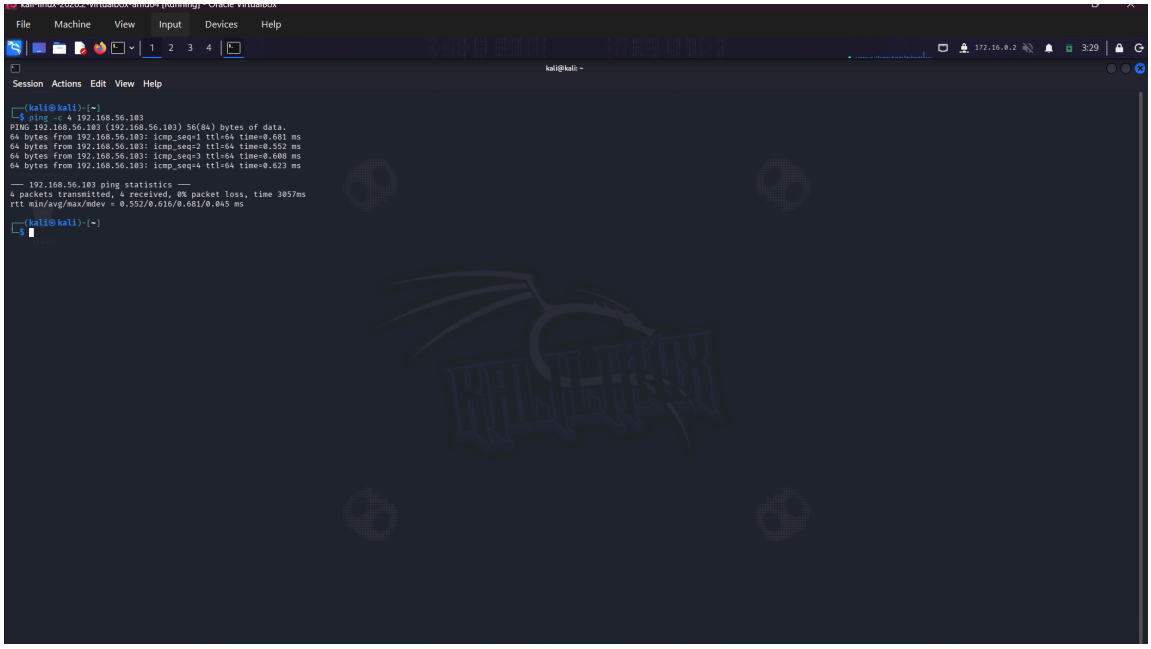
2. Practical Execution & Evidence

Step A: Host Discovery (Ping Sweep)

- **Command Executed:**

```shell
ping -c 4 192.168.56.103
```

- **Purpose:** Confirmed ICMP reachability and network connection to the target virtual machine with 0% packet loss.

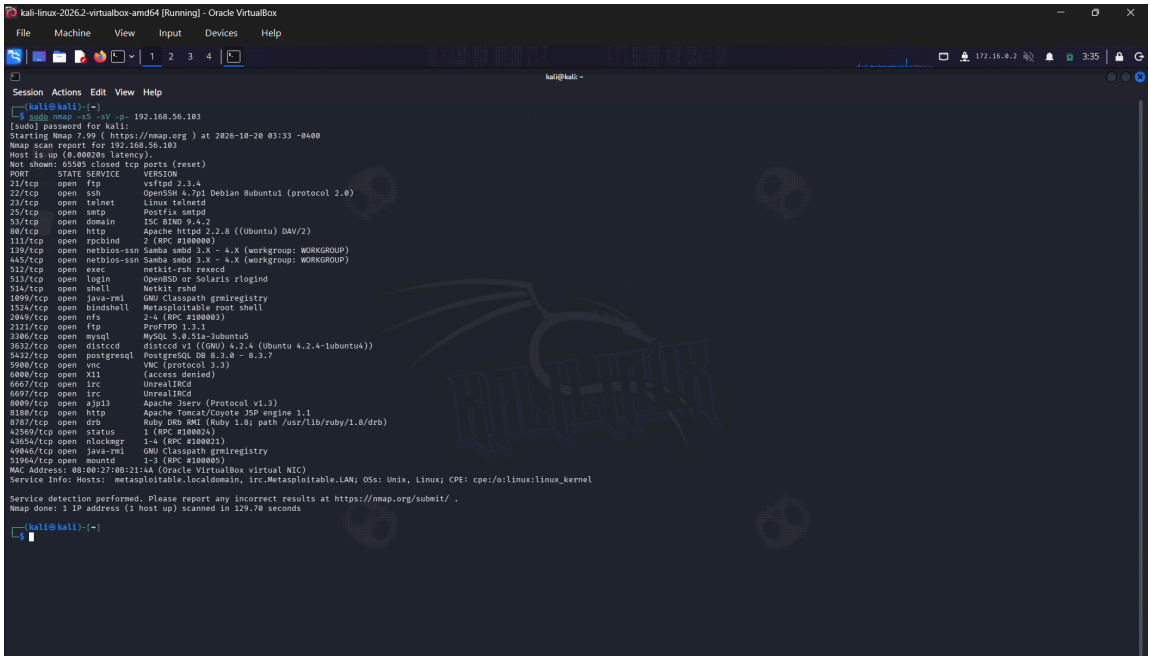
- 

Step B: Comprehensive Port & Service Scan

- **Command Executed:**

```shell
sudo nmap -sS -sV -p- 192.168.56.103
```

- **Purpose:** Performed a stealth TCP SYN scan (`-sS`) combined with service banner version detection (`-sV`) across all 65,535 TCP ports (`-p-`).

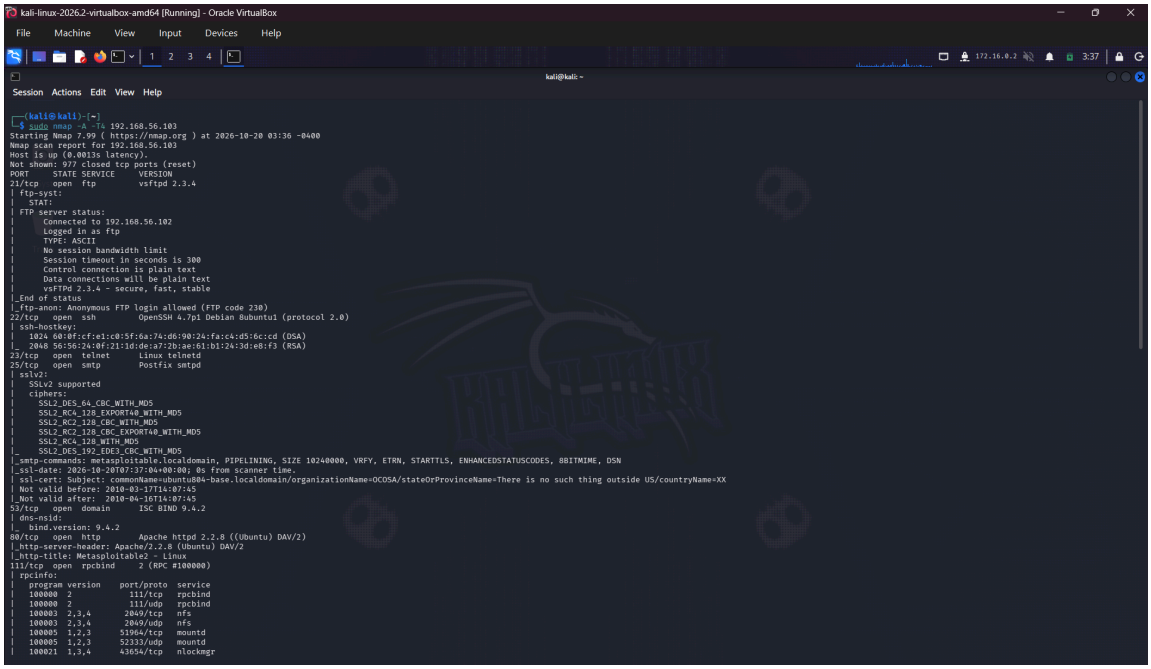
- 

Step C: Aggressive Enumeration & OS Fingerprinting

- **Command Executed:**

```shell
sudo nmap -A -T4 192.168.56.103
```

- **Purpose:** Fingerprinted operating system information and executed default service scripts at an accelerated timing template (`-T4`).

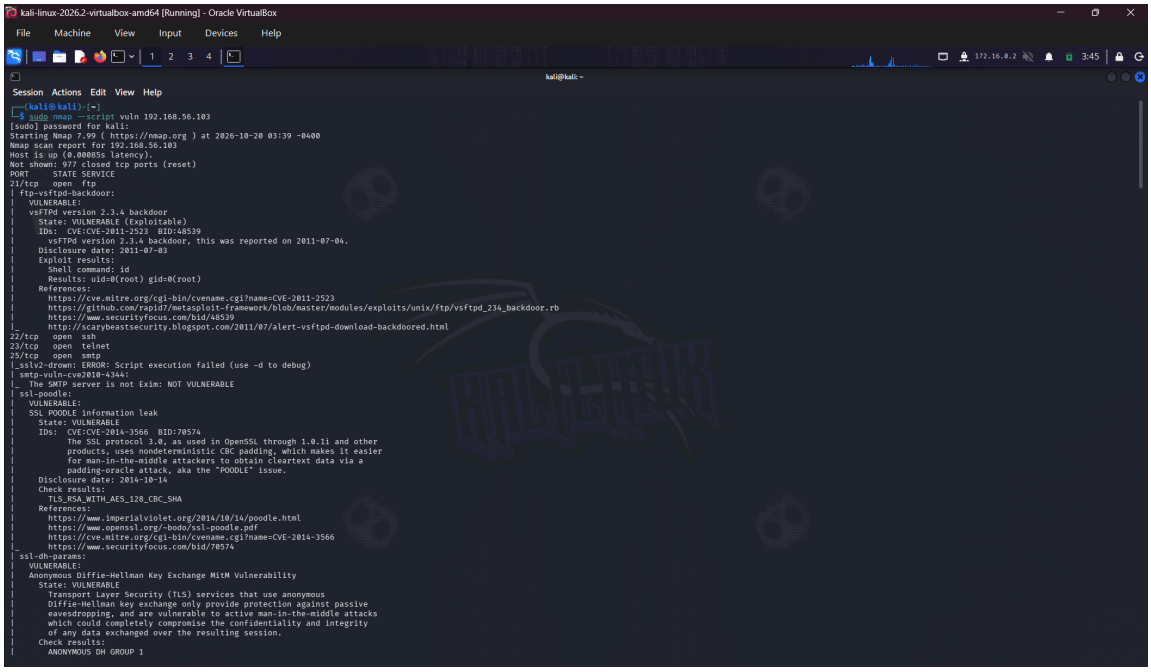
- 

Step D: Vulnerability Detection via Nmap Scripting Engine (NSE)

- **Command Executed:**

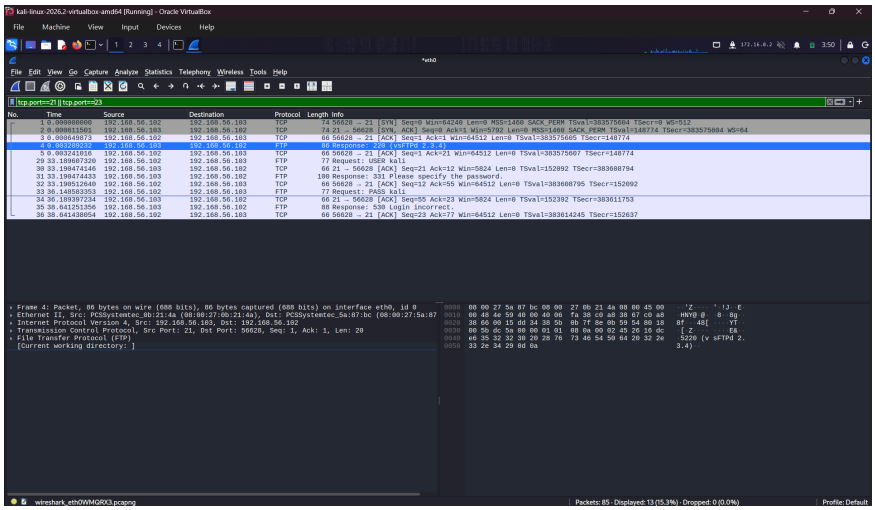
```
Shell
sudo nmap --script vuln 192.168.56.103
```

- **Purpose:** Probed active services for high-risk vulnerabilities and CVE listings using Nmap's vulnerability detection scripts.

- 

Step E: Traffic Capture & Network Analysis

- **Execution Steps:**
    1. Launched Wireshark on Kali Linux bound to the host-only interface (`vboxnet0`).
    2. Captured live packet streams while interacting with target services.
    3. Filtered traffic (`tcp.port == 21 || tcp.port == 23`) to analyze cleartext packet payload data.

- 

---

3. Vulnerability Findings & Mitigation Strategies

Port / Service	Vulnerability Identified	Severity	Technical Description & Remediation Strategy
21/tcp (FTP)	`vsftpd 2.3.4` Backdoor	**Critical**	Contains a known backdoor (`CVE-2011-2523`) triggering an unauthenticated root command shell on TCP port 6200 when specific string sequences are processed. `  `**Mitigation:** Upgrade `vsftpd` to the latest stable release or replace the FTP service with SFTP/SCP.
23/tcp (Telnet)	Cleartext Authentication	**High**	Transmits all session traffic, credentials, and administrative commands in unencrypted plain text, exposing logins to packet sniffing. `  `**Mitigation:** Disable Telnet (`service openbsd-inetd stop`) and

Port / Service	Vulnerability Identified	Severity	Technical Description & Remediation Strategy
			enforce SSH (Port 22) with public-key authentication.
80/tcp (HTTP)	Vulnerable Web Apps (DVWA)	**High**	Hosts legacy web application environments containing unvalidated input parameters vulnerable to SQL Injection (SQLi) and Cross-Site Scripting (XSS). `  `**Mitigation:** Implement Parameterized Queries (Prepared Statements), strict input sanitization, and output encoding.
445/tcp (SMB)	Samba `usermap_script` RCE	**Critical**	Contains an input validation flaw (`CVE-2007-2447`) when processing usernames in `smb.conf`, permitting remote code execution with root privileges. `  `**Mitigation:** Patch Samba to version >= 3.0.25a and restrict SMB access via firewall rules (`iptables`).

Detailed Mitigation & Remediation Strategies

1. FTP Service (`vsftpd 2.3.4` Backdoor — Port 21)

- **Remediation Action:** Upgrade the `vsftpd` package to the latest stable version or remove the compromised package entirely.
- **Commands / Fix:**
- Bash

Update package repository and upgrade vsftpd

sudo apt-get update && sudo apt-get install --only-upgrade vsftpd

Or disable FTP entirely if not required

sudo systemctl stop vsftpd

sudo systemctl disable vsftpd

-
-
- **Best Practice:** If file transfers are required, replace unencrypted FTP with **SFTP (SSH File Transfer Protocol)** or **FTPS (FTP over TLS)** with strong key authentication.

2. Telnet Service (Cleartext Authentication — Port 23)

- **Remediation Action:** Disable the Telnet service daemon completely. Telnet transmits usernames, passwords, and commands in plaintext across the network.
- **Commands / Fix:**
- Bash

Stop and disable Telnet daemon

sudo systemctl stop inetd

sudo systemctl disable inetd

-
-
- **Best Practice:** Enforce encrypted remote administration exclusively using **SSH (Secure Shell)** on port 22. Disable root login over SSH and use SSH key pairs instead of passwords.

3. Web Application (DVWA / Apache — Port 80)

- **Remediation Action:** Remove or isolate legacy test/vulnerable applications (such as DVWA, Mutillidae) from production web servers.
- **Fixes & Code Hardening:**
    - **SQL Injection Fix:** Use parameterized queries (Prepared Statements) in database interactions instead of concatenating raw user input.
    - **XSS Fix:** Sanitize and escape all user input before rendering it in the HTML DOM (e.g., using `htmlspecialchars()` in PHP).
    - **Server Hardening:** Update Apache web server packages, hide server tokens (`ServerTokens Minimal`), and implement web application firewalls (WAF) like **ModSecurity**.

4. Samba Service (`usermap_script` RCE — Port 445)

- **Remediation Action:** Patch the Samba service to a non-vulnerable release (Samba 3.0.25 or higher patched) and restrict network access.
- **Commands / Fix:**
- Bash

Upgrade Samba package

sudo apt-get update && sudo apt-get install --only-upgrade samba

Firewall rule: Block external access to SMB ports (139, 445)

sudo ufw deny 445/tcp

sudo ufw deny 139/tcp

-
-
- **Best Practice:** Ensure SMB signing is enforced and legacy SMBv1 protocol is completely disabled across the network.